Cuestionario: Primer Parcial - Seguridad Ofensiva

Pregunta 1 (Ensayo)

Escenario: Una entidad financiera solicita evaluar si un empleado administrativo con una cuenta estándar podría escalar privilegios para acceder a la base de datos central. Durante la ejecución en un entorno de nube compartida, el pentester descubre accidentalmente que sus escaneos están alcanzando servidores de otras empresas ajenas al contrato.

- **A:** Identifique y justifique qué tipo de prueba (Blackbox, Greybox o Whitebox) es la más adecuada para simular el escenario del empleado interno.
- **B:** Explique las implicancias legales de haber escaneado sistemas de terceros en la nube y cuál es el procedimiento correcto a seguir según la ética profesional.

Pregunta 2 (Opción Múltiple)

Escenario: Un pentester quiere saber si un sistema es vulnerable antes de lanzar un exploit real que podría causar inestabilidad. Un colega dice que no existe forma de verificar esto sin ejecutar el exploit. **Pregunta:** ¿Tiene razón el colega? ¿Qué opción ofrece Metasploit para este caso?

- **A)** El colega tiene razón; la única forma de confirmar vulnerabilidad es ejecutar el exploit completo.
- **B)** No tiene razón; el comando 'check' permite verificar si el objetivo es vulnerable a un exploit específico sin llegar a explotarlo.
- **C)** El colega está en lo correcto; sin embargo, se puede usar un payload 'NoNX' que es menos invasivo.
- **D)** No tiene razón; el comando 'info' ejecuta una comprobación automática de vulnerabilidad sin lanzar el exploit.

Pregunta 3 (Opción Múltiple)

Escenario: Un atacante envía un email con un enlace a una página web maliciosa. La víctima hace clic y, al cargar la página en su navegador desactualizado, se ejecuta código remoto sin interacción adicional. **Pregunta:** Identifique correctamente el 'vector de ataque' y el 'exploit' en este escenario:

- **A)** Vector de ataque: el navegador desactualizado; Exploit: el email enviado.
- **B)** Vector de ataque: la ejecución de código remoto; Exploit: la vulnerabilidad del navegador.
- **C)** Vector de ataque y exploit son el mismo elemento: la página web maliciosa.

- **D)** Vector de ataque: el enlace enviado por email que lleva a la página maliciosa; Exploit: el código que aprovecha la vulnerabilidad del navegador.

Pregunta 4 (Opción Múltiple)

Escenario: Una aplicación bancaria en producción falla intermitentemente al procesar transferencias con nombres de beneficiario muy largos. El equipo de desarrollo descarta un bug de seguridad y lo atribuye a un error de visualización. Un auditor de seguridad discrepa. **Pregunta:** ¿Qué debería investigar el auditor de seguridad como primera hipótesis técnica?

- **A)** Una posible inyección SQL en el campo de nombre del beneficiario.
- **B)** Un ataque de denegación de servicio distribuido (DDoS) dirigido al módulo de transferencias.
- **C)** Un desbordamiento de buffer (buffer overflow), ya que la entrada de longitud excesiva podría estar sobrescribiendo zonas de memoria adyacentes.
- **D)** Un error de codificación de caracteres (UTF-8 vs ASCII) que provoca corrupción visual.

Pregunta 5 (Opción Múltiple)

Escenario: Un pentester completa la fase de explotación y obtiene acceso a un servidor crítico. En post-explotación instala un backdoor persistente y crea un usuario oculto sin notificar al cliente estas acciones específicas. **Pregunta:** ¿Qué problema ético y operacional plantea esta situación?

- **A)** Ninguno: la post-explotación y el mantenimiento de acceso son fases estándar que implican necesariamente dejar artefactos para demostrar persistencia real.
- **B)** El problema es únicamente técnico: el backdoor podría ser descubierto por el IDS del cliente y comprometer la confidencialidad del engagement.
- **C)** Esta práctica es aceptable si el informe técnico final detalla el backdoor; la notificación previa no es requerida en contratos de 'full scope post-exploitation'.
- **D)** Las acciones de post-explotación que afecten la integridad del sistema deben estar explícita y previamente autorizadas en el scope.

Pregunta 6 (Opción Múltiple)

Pregunta: Nmap reporta un puerto como 'filtered'. Un analista lo interpreta como 'el puerto está cerrado y no hay servicio activo'. ¿Por qué esta interpretación es incorrecta?

- **A)** La interpretación es correcta: 'filtered' en nmap indica que el puerto no está en uso y no hay ningún servicio activo escuchando.

- **B)** Filtered indica que el puerto está abierto pero requiere autenticación previa antes de responder a las solicitudes de conexión.
- **C)** Filtered significa que un firewall, ACL de router u otro dispositivo de red está bloqueando o descartando los paquetes de escaneo antes de que lleguen al host objetivo.
- **D)** El estado filtered solo aparece cuando nmap detecta un honeypot que deliberadamente no responde para evitar revelar el estado real del puerto.

Pregunta 7 (Opción Múltiple)

Escenario: Un servidor web responde con: 'Apache/2.4.51 (Ubuntu)'. El administrador afirma que esta información no representa riesgo. **Pregunta:** ¿Por qué el administrador subestima el riesgo?

- **A)** El administrador tiene razón: revelar la versión del servidor es información genérica sin valor para un atacante porque las vulnerabilidades se parchean automáticamente.
- **B)** El riesgo está en revelar que usa Apache en lugar de un servidor propietario; la versión específica no agrega información útil para un atacante.
- **C)** El riesgo solo es relevante si el servidor está directamente expuesto a internet; en redes internas los banners no representan riesgo.
- **D)** La versión exacta del servidor permite al atacante buscar CVEs específicos de esa versión en exploit-db o NVD.

Pregunta 8 (Opción Múltiple)

Escenario: Un cliente solicita un pentest para evaluar si un empleado interno con acceso de usuario estándar podría comprometer la infraestructura completa. **Pregunta:** ¿Qué tipo de pentest describe con mayor precisión este escenario y por qué?

- **A)** Blackbox, porque el pentester simula un atacante externo que descubre la infraestructura progresivamente desde cero, sin conocimiento previo del entorno.
- **B)** Greybox, porque el escenario plantea un usuario con privilegios limitados cuyo objetivo es escalar privilegios para obtener control sobre la infraestructura; es exactamente el caso de uso definido para este tipo de análisis.
- **C)** Whitebox, porque el pentester tiene acceso completo al código fuente y configuraciones internas del entorno para un análisis exhaustivo de backdoors.
- **D)** Blackbox y Whitebox en paralelo, porque evaluar amenazas internas requiere combinar ambas perspectivas simultáneamente.

Pregunta 9 (Opción Múltiple)

Escenario: Un pentester entrega un único informe con todos los comandos ejecutados, exploits utilizados, payloads y shells obtenidas. El CEO no entiende el documento. **Pregunta:** ¿Qué falla metodológica cometió el pentester?

- **A)** Ninguna: el informe técnico debe ser el único entregable; es responsabilidad del CEO contratar personal técnico que lo interprete.
- **B)** El problema es de confidencialidad: los comandos y payloads no deben incluirse en ningún informe porque revelan las técnicas del pentester.
- **C)** El pentester no produjo un informe ejecutivo diferenciado. El informe ejecutivo debe usar lenguaje no técnico, mostrar el impacto de negocio y conclusiones orientadas a la gerencia.
- **D)** El informe es correcto pero debería haberse entregado solo al CISO, nunca directamente al CEO.

Pregunta 10 (Opción Múltiple)

Escenario: Un programa tiene dos variables contiguas en memoria: un buffer de 8 bytes (A) y un entero de 2 bytes (B) con valor 3. Un desarrollador escribe la cadena 'demasiado' (9 caracteres + terminador) en A sin validar la longitud. **Pregunta:** ¿Qué ocurre exactamente con el valor de B tras esta operación, y qué principio de seguridad fue violado?

- **A)** B es sobrescrito con parte de la cadena escrita en A, ya que no se validó la longitud del dato copiado, violando el principio de validación de entradas.
- **B)** B conserva su valor de 3; el sistema operativo protege variables adyacentes automáticamente.
- **C)** B es truncado a 0 como medida de seguridad del compilador al detectar el overflow.
- **D)** B duplica su valor a 6 como efecto secundario del overflow en arquitecturas x86.

Pregunta 11 (Opción Múltiple)

Escenario: Una organización descubrió que un atacante externo explotó una vulnerabilidad en su servidor web enviando una cadena de entrada muy larga. El sistema no validó el tamaño del input y el atacante logró ejecutar código remoto. **Pregunta:** Según los conceptos estudiados, ¿qué tipo de vulnerabilidad explotó el atacante y qué medida preventiva básica debería haberse implementado?

- **A)** Buffer overflow; debería validarse la longitud de la entrada antes de procesarla.
- **B)** Inyección SQL; debería haberse usado prepared statements en las consultas a la base de datos.
- **C)** Cross-Site Scripting (XSS); debería haberse sanitizado el HTML de salida.

- **D)** Escalamiento de privilegios; debería haberse limitado los permisos del proceso del servidor web.

Pregunta 12 (Opción Múltiple)

Escenario: El siguiente código en C forma parte de un sistema de autenticación: `char password[8]; strcpy(password, input_usuario);` Un auditor marca esto como una vulnerabilidad crítica. El desarrollador defiende el código diciendo: 'Los usuarios no van a ingresar contraseñas de más de 8 caracteres.' **Pregunta:** ¿Por qué la defensa del desarrollador es técnicamente inadecuada?

- **A)** Un atacante no está limitado por las políticas de la aplicación; puede enviar directamente datos arbitrarios al servidor.
- **B)** Tiene razón; si la política de contraseñas limita a 8 caracteres, strcpy es seguro.
- **C)** La validación debería hacerse en el cliente (frontend), no en el servidor.
- **D)** El riesgo es bajo porque strcpy solo es peligroso en sistemas operativos Windows.

Pregunta 13 (Opción Múltiple)

Escenario: Una empresa de e-commerce contrató a un equipo de seguridad para evaluar sus sistemas. El líder del equipo propone utilizar Metasploit Framework. Un miembro junior del equipo pregunta: '¿Por qué usar esta herramienta si es de código abierto y cualquier atacante también puede usarla?' **Pregunta:** ¿Cuál es la respuesta más técnicamente precisa a la preocupación del miembro junior?

- **A)** El miembro junior tiene razón: usar herramientas públicas representa un riesgo legal para la empresa.
- **B)** Precisamente porque los atacantes la usan, los pentesters deben conocerla para identificar los mismos vectores que explotaría un adversario real, bajo condiciones controladas y autorizadas.
- **C)** Metasploit Framework es una herramienta exclusiva para uso defensivo y no puede usarse para ataques reales.
- **D)** Solo la versión comercial Metasploit Pro es legal para pruebas en empresas; la versión open source está prohibida en entornos productivos.

Pregunta 14 (Opción Múltiple)

Escenario: Un pentester usa únicamente nmap -sV para enumerar servicios y versiones en todos los hosts y concluye que no hay vulnerabilidades web explotables. Un colega cuestiona la conclusión. **Pregunta:** ¿Por qué este enfoque es metodologicamente insuficiente para evaluar la superficie web?

- **A)** El colega está equivocado: nmap -sV es suficiente para detectar todas las vulnerabilidades de servicios web al identificar las versiones del software en ejecución.
- **B)** El problema es que nmap no detecta CVEs; se necesita Nessus para correlacionar versiones con la base CVE nacional.
- **C)** nmap -sV con el script -sC es completamente equivalente a Burp Suite para evaluación de aplicaciones web.
- **D)** Nmap -sV identifica servicios y versiones pero no analiza el comportamiento dinámico de aplicaciones web: no detecta vulnerabilidades de lógica de negocio e inyecciones (SQLi, XSS).

Pregunta 15 (Opción Múltiple)

Escenario: Un pentester descarga un exploit desde Exploit Database para probar un servidor objetivo. Antes de ejecutarlo, un colega senior le advierte: 'Eso puede contener código malicioso.' El pentester responde: 'Es de una fuente pública confiable, no hay problema.' **Pregunta:** ¿Cuál de los dos tiene razón, y qué precaución indica el material al respecto?

- **A)** El pentester tiene razón; Exploit Database es mantenida por Offensive Security y todo el código es auditado.
- **B)** Ambos tienen razón: el código es seguro si proviene de sitios reconocidos, pero hay que tener cuidado en sitios no verificados.
- **C)** El colega tiene razón; el material advierte que se debe tener mucho cuidado al descargar y ejecutar código de repositorios públicos, ya que podría contener código malicioso.
- **D)** El colega está equivocado; los exploits de fuentes públicas están certificados digitalmente y son seguros por definición.

Pregunta 16 (Opción Múltiple)

Escenario: Durante un pentest blackbox, el pentester descubre que sistemas del scope están alojados en un proveedor cloud compartido con otros clientes. Al escanear el rango IP del target, inadvertidamente envía paquetes a sistemas de terceros clientes del mismo proveedor. **Pregunta:** ¿Cuál es la implicancia legal y la acción correcta?

- **A)** Escanear sistemas de terceros sin autorización constituye acceso no autorizado independientemente de si fue inadvertido.
- **B)** No hay implicancia legal porque el escaneo fue inadvertido; la intención determina la legalidad y el pentester tenía autorización del cliente original.
- **C)** La autorización del cliente cubre automáticamente todos los sistemas en el mismo datacenter o rango IP, incluyendo los de terceros alojados en la misma infraestructura.

- **D)** El pentester debe continuar pero excluir del informe cualquier hallazgo en sistemas de terceros para proteger la confidencialidad del engagement.

Pregunta 17 (Opción Múltiple)

Escenario: Un analista describe el Footprinting como 'enviar paquetes al target para descubrir hosts activos'. **Pregunta:** ¿Por qué esta descripción es incorrecta y cuál es la diferencia técnica fundamental?

- **A)** La descripción es correcta: Footprinting y Scanning son términos intercambiables que describen el mismo proceso de reconocimiento activo.
- **B)** El Footprinting es reconocimiento pasivo o semi-pasivo: recopila información sobre el target desde fuentes públicas.
- **C)** El Footprinting es más agresivo que el Scanning porque involucra técnicas activas como SNMP walking y SMB enumeration.
- **D)** Ambas fases son activas; la diferencia es que el Footprinting se hace desde fuera de la red y el Scanning desde dentro.

Soluciones y Clave de Respuestas

- *(Nota: Para la **Pregunta 1 (Ensayo)**, la respuesta correcta debe enfocarse en justificar el modelo **Greybox** por simular exactamente a un usuario interno con privilegios limitados. En la parte B, se debe aclarar que escaneos a terceros sin autorización violan el NDA/marco legal y que se debe **detener el escaneo de inmediato** y reportarlo/ajustar el scope).*
- **Pregunta 2:** B
- **Pregunta 3:** D
- **Pregunta 4:** C
- **Pregunta 5:** D
- **Pregunta 6:** C
- **Pregunta 7:** D
- **Pregunta 8:** B
- **Pregunta 9:** C
- **Pregunta 10:** A
- **Pregunta 11:** A
- **Pregunta 12:** A
- **Pregunta 13:** B
- **Pregunta 14:** D
- **Pregunta 15:** C
- **Pregunta 16:** A
- **Pregunta 17:** B

Acá tenés el **Segundo Parcial completo y ordenado numéricamente** del 1 al 16 para que puedas practicar de corrido y sin interrupciones.

(Nota: Revisando todas las capturas que me enviaste, la pregunta 13 no estaba en ninguna de las imágenes, por lo que saltamos de la 12 a la 14. ¡Si la llegás a encontrar, pasámela y la sumamos!)

Al final del mensaje te dejo la clave de respuestas de todo el examen. ¡A practicar!

Cuestionario: Segundo Parcial - Seguridad Ofensiva

Pregunta 1 (Opción Múltiple)

Escenario: Un pentester entregó un payload de dos etapas a la víctima. La primera etapa (stager) se ejecuta correctamente y establece conexión con el equipo atacante. Sin embargo, la sesión nunca se materializa: el handler muestra intentos de conexión pero ninguna sesión activa. El análisis de red en el equipo atacante muestra que la primera conexión TCP llega, pero un segundo intento de descarga hacia el mismo puerto es bloqueado por un proxy de inspección de contenido corporativo. **Pregunta:** ¿Qué propiedad arquitectónica del payload staged explica por qué el proxy interrumpe el ataque en este punto específico?

- **A)** El proxy bloquea la primera conexión TCP; si el stager llega al handler es porque el proxy no interviene. El problema está en la configuración del handler, no en la arquitectura del payload.
- **B)** El problema es exclusivamente de protocolo: los payloads staged solo funcionan sobre TCP puro; cualquier proxy HTTP interrumpe la comunicación. Usar UDP resolvería el problema independientemente de si el payload es staged o non-staged.
- **C)** El stager falló porque el proxy realizó deep packet inspection sobre la primera conexión. Tanto el modelo staged como el non-staged son igualmente vulnerables a este tipo de inspección en la primera etapa.
- **D)** El modelo staged requiere que el stager descargue el stage completo en una segunda comunicación de red independiente. Si el proxy inspecciona y bloquea esa segunda solicitud, el stage nunca se transfiere y la sesión no puede completarse.

Pregunta 2 (Opción Múltiple)

Escenario: Una auditoría externa concluye que el perímetro de red de una empresa está correctamente endurecido: sin servicios expuestos innecesariamente, todos los componentes con parches al día, firewall con política de denegación por defecto. El CISO declara el riesgo externo como 'bajo' y reduce el presupuesto de simulaciones de ataque. Seis meses después, la empresa sufre un compromiso que comenzó con un empleado que abrió un documento enviado por correo electrónico. **Pregunta:**

¿Qué falla conceptual en el modelo de seguridad del CISO permitió este incidente, y cómo debería replantearse la relación entre el endurecimiento del perímetro y el riesgo residual?

- **A)** La falla fue presupuestaria: reducir el presupuesto de simulaciones fue el error crítico. Si las simulaciones hubieran continuado, el documento malicioso habría sido detectado antes.
- **B)** La falla fue técnica: el servidor de correo debía filtrar documentos adjuntos. El CISO tenía razón en evaluar el perímetro de red como bajo riesgo; el problema estaba en un control específico que faltaba.
- **C)** El perímetro endurecido es condición suficiente para riesgo bajo cuando se combina con un firewall de denegación por defecto. El incidente ocurrió por un fallo humano que no puede ser prevenido con controles técnicos, y ese riesgo es aceptable.
- **D)** La ingeniería social usa al usuario para saltarse el perímetro desde adentro: al abrir el archivo, la conexión de retorno es tráfico saliente legítimo. El riesgo residual post-endurecimiento técnico abarca, justamente, todo vector que no dependa de vulnerabilidades expuestas.

Pregunta 3 (Opción Múltiple)

Escenario: Un red team prepara un payload que será entregado a través de un documento de Office. El sistema de seguridad del objetivo incluye un sandbox de correo electrónico que analiza todos los adjuntos. El equipo observa que el sandbox reporta el documento como limpio, pero cuando un usuario real lo abre días después, se establece una sesión de control remoto. El sandbox tenía acceso a internet durante el análisis. **Pregunta:** ¿Qué característica del payload o de su lógica de activación puede explicar que el sandbox lo reportara como limpio y el usuario real activara la sesión?

- **A)** El sandbox reportó el documento como limpio porque los documentos de Office nunca son ejecutados en sandboxes de correo; solo se analiza su contenido estático. Cualquier documento con macros pasará un sandbox de correo.
- **B)** El payload puede incluir lógica de detección de entorno que evalúa condiciones antes de activarse: tiempo mínimo de ejecución del sistema, presencia de interacción humana, etc. Si el payload no detecta las condiciones de entorno real, no intenta establecer la conexión, comportándose como un documento benigno. El sandbox agota su ventana de análisis sin ver comportamiento malicioso.
- **C)** El sandbox no tiene la firma del payload específico del red team. Una vez que el vendor de seguridad agregue esa firma, el sandbox lo detectará. No hay una técnica de evasión específica en este caso.
- **D)** El sandbox reportó el documento como limpio porque el payload usa cifrado en las comunicaciones; el sandbox no puede inspeccionar tráfico

cifrado y por lo tanto no detecta la conexión de retorno incluso cuando se establece durante el análisis.

Pregunta 4 (Opción Múltiple)

Escenario: El equipo de respuesta a incidentes de una empresa analiza un ataque completado. La cadena de eventos fue: un empleado recibió un correo imitando a un proveedor de confianza; abrió un documento adjunto que ejecutó un script que descargó un archivo desde internet; ese archivo cifró los discos del equipo. El CISO caracteriza el incidente como 'un ataque de ransomware por correo electrónico'. **Pregunta:** ¿Por qué la descripción del CISO, aunque parcialmente correcta, es insuficiente para informar una respuesta defensiva adecuada, y cómo debería descomponerse el incidente?

- **A)** La descripción es correcta y completa: el vector fue el correo electrónico y el tipo de malware fue ransomware. No hay información adicional relevante para la respuesta defensiva.
- **B)** La descripción del CISO es insuficiente porque no menciona el vector técnico específico. Para la respuesta defensiva, lo único relevante es el tipo de malware (ransomware); el resto de la cadena es contexto operacional sin valor para los controles.
- **C)** La descripción es incorrecta: los ataques de ransomware por correo electrónico no existen técnicamente porque los filtros antispam bloquean todos los correos con adjuntos maliciosos. El vector real debe haber sido otro.
- **D)** El argumento reduce tres fases a una sola: ingeniería social (correo), entrega (script en documento) y payload (cifrado). Mitigar el riesgo exige controles específicos para cada capa. Tratar el incidente llanamente como "ransomware por correo" limita la defensa solo a la capa visible, ignorando los eslabones intermedios.

Pregunta 5 (Opción Múltiple)

Escenario: Una empresa manufacturera sufre un ataque de ransomware que cifra sus servidores de producción. Los atacantes exigen rescate. La empresa tiene copias de respaldo de hace 48 horas. El director de operaciones argumenta que pagar el rescate es más rápido que restaurar desde copia de respaldo, y que una vez pagado y descifrado el entorno, el problema habrá sido resuelto. **Pregunta:** ¿Qué hipótesis crítica invalida el razonamiento del director de operaciones, y qué implica técnicamente para la estrategia de recuperación?

- **A)** El razonamiento es válido si el monto del rescate es inferior al costo de 48 horas de inactividad. La decisión es puramente económica y el director tiene razón en considerar la velocidad de recuperación.

- **B)** El ransomware es solo la fase final del ataque, no el evento completo; antes ocurren la persistencia y la exfiltración. Pagar el rescate o restaurar los sistemas sin una investigación forense que erradique los accesos previos implantados por el atacante condena a la organización a sufrir una reinfección inmediata.
- **C)** El razonamiento es incorrecto solo porque los grupos de ransomware no entregan claves de descifrado funcionales después del pago. La única opción viable es siempre restaurar desde copia de respaldo.
- **D)** El director tiene razón en la velocidad de recuperación, pero se equivoca en el costo: el pago de rescate siempre es más caro que la restauración desde backup cuando se incluyen los costos indirectos de la negociación.

Pregunta 6 (Opción Múltiple)

Escenario: El equipo forense de una organización financiera encuentra en la memoria de un servidor comprometido un módulo que intercepta todas las entradas de teclado en el contexto de las aplicaciones financieras del servidor. El módulo no está en disco en ninguna forma reconocible. El sistema antivirus del servidor, con firmas actualizadas, no ha generado ninguna alerta en los últimos 30 días.
Pregunta: ¿Qué propiedades del módulo identificado explican la ausencia de detección por el antivirus basado en firmas, y qué tipo de control es más adecuado para detectar esta categoría de amenaza?

- **A)** El antivirus falló porque sus firmas estaban desactualizadas a pesar de lo indicado. Un antivirus con firmas realmente actualizadas detecta cualquier módulo de captura de teclado independientemente de su forma.
- **B)** El problema es que el antivirus solo analiza el tráfico de red y no los procesos en memoria. Implementar un antivirus que también analice el tráfico de red detectaría el módulo cuando exfiltra las credenciales capturadas.
- **C)** La ausencia de detección indica que el módulo fue instalado por un usuario con privilegios de administrador que tiene capacidad de deshabilitar el antivirus selectivamente. El control correcto es restringir los privilegios de administrador en el servidor.
- **D)** El antivirus no lo detecta porque la falta de archivo en disco anula el análisis estático, y su actividad (keylogger) imita a software legítimo, burlando la heurística. Para mitigarlo, se requiere un control de integridad de procesos en memoria que monitoree inyecciones, llamadas al sistema anómalas y módulos cargados sin representación física en el almacenamiento.

Pregunta 7 (Opción Múltiple)

Escenario: El equipo de seguridad de una empresa detecta y elimina un troyano del sistema operativo de un servidor. El proceso malicioso es terminado y el archivo ejecutable es borrado del disco. Dos días después, el mismo troyano vuelve a aparecer activo. Al investigar, no encuentran ninguna copia adicional del ejecutable

en disco. **Pregunta:** ¿Qué mecanismo técnico explica la reaparición del troyano sin una copia en disco, y por qué la respuesta al incidente fue incompleta?

- **A)** El troyano reapareció porque el sistema operativo tiene una función de recuperación automática que restaura archivos del sistema eliminados accidentalmente. La solución es deshabilitar esta función antes de eliminar malware.
- **B)** El troyano reapareció porque el disco fue infectado a nivel de firmware. La única solución es reemplazar el disco físicamente, ya que ningún análisis de sistema operativo puede detectar ni eliminar infecciones a nivel de firmware.
- **C)** La reaparición indica que otro equipo de la red está reinfectando el servidor. El servidor está en una red segmentada incorrectamente que permite tráfico lateral, y la solución es aislar el servidor de todos los demás.
- **D)** Eliminar solo el artefacto visible sin neutralizar el mecanismo de persistencia (tareas programadas, registros de inicio o inyecciones) causa la reaparición del troyano. La remediación efectiva requiere una investigación que identifique y erradique los vectores ocultos que recrean el ejecutable principal.

Pregunta 8 (Opción Múltiple)

Escenario: Un ingeniero de redes afirma en una reunión que las redes modernas con switches gestionados son inmunes al envenenamiento de caché ARP porque los switches controlan el reenvío de tramas por puerto y las tablas de asociación MAC-puerto impiden que un equipo reciba tramas no destinadas a él. **Pregunta:** ¿Dónde radica el error técnico en el argumento del ingeniero, y qué propiedad del protocolo ARP hace que la arquitectura switched no sea una defensa suficiente?

- **A)** El argumento es correcto: los switches modernos con tablas MAC actualizadas dinámicamente impiden el envenenamiento ARP porque los paquetes solo llegan al puerto del destinatario real.
- **B)** El ingeniero tiene razón en que los switches modernos son inmunes, pero solo para versiones del protocolo ARP anteriores a ARP v2. Las versiones modernas del protocolo incluyen campos de autenticación que los switches validan.
- **C)** Se confunde el mapeo de puertos del switch con la caché ARP de los dispositivos finales. Al carecer ARP de autenticación, un atacante puede enviar respuestas falsas no solicitadas a los hosts. Una vez que las víctimas asocian la IP del gateway con la MAC del atacante, el tráfico se redirige hacia él, independientemente de que el switch conozca correctamente la asociación MAC-puerto.
- **D)** El argumento es correcto para trafico unicast pero incorrecto para trafico broadcast. Los ataques de envenenamiento ARP solo funcionan enviando paquetes broadcast que el switch distribuye a todos los puertos, y esto puede prevenirse deshabilitando el broadcast en el switch.

Pregunta 9 (Opción Múltiple)

Escenario: Un equipo de seguridad realiza una prueba de MitM en su propia red corporativa. Observan que aunque todo el tráfico usa TLS y los usuarios ven el candado verde en el navegador, el equipo puede leer el contenido del tráfico cifrado durante la prueba. Los usuarios no recibieron ninguna advertencia de certificado. Al investigar, encuentran que la empresa había instalado un certificado de autoridad de certificación raíz corporativo en todos los equipos para inspección de tráfico saliente. **Pregunta:** ¿Qué mecanismo exacto permite leer el trafico TLS sin que los usuarios reciban advertencias, y qué implicaciones tiene esto para el modelo de confianza TLS?

- **A)** TLS puede ser interceptado sin advertencias porque el protocolo tiene una vulnerabilidad conocida que permite degradar la conexión a texto plano. El candado verde no garantiza cifrado real en redes corporativas.
- **B)** El equipo lee el tráfico porque usa claves efímeras Diffie-Hellman que pueden ser reconstruidas a posteriori conociendo los parámetros de la sesión. El candado verde es correcto pero TLS con claves efímeras es retroactivamente descifrable.
- **C)** El escenario es imposible: si el trafico usa TLS correcto y los usuarios ven el candado verde, no hay forma técnica de interceptar el contenido. El equipo de seguridad debe haber tenido acceso a los servidores de destino para obtener las claves privadas.
- **D)** Mediante la instalación de una CA raíz corporativa en el dispositivo, el proxy intercepta la conexión TLS y emite un certificado falso pero válido para el navegador. Así, el modelo de confianza TLS deja de garantizar una comunicación extremo a extremo absoluta: solo valida que el canal es seguro con una entidad autorizada por el almacén de confianza local, actúe esta o no como intermediaria.

Pregunta 10 (Opción Múltiple)

Escenario: El equipo de respuesta a incidentes de un proveedor de internet detecta que un grupo de dispositivos de clientes genera tráfico de red con un patrón inusual: cada dispositivo realiza consultas periódicas a un conjunto de dominios que rotan semanalmente, con nombres de dominio que parecen generados algorítmicamente. El tráfico es de bajo volumen individual pero masivo en conjunto. Los dispositivos afectados parecen funcionar normalmente. **Pregunta:** ¿Qué arquitectura de control remoto describe este patrón, y qué capacidad de los operadores de la botnet explica la rotación semanal de dominios?

- **A)** La arquitectura de mando y control utiliza DGA (Algoritmos de Generación de Dominios) para automatizar una rotación semanal de dominios deterministas. Al registrar solo un subconjunto por período, el atacante dota a la botnet de resiliencia frente a las listas negras: para cuando los defensores

identifican y bloquean el grupo actual de dominios, los hosts infectados ya migraron al siguiente.
- **B)** El patrón describe tráfico legítimo de actualización automática de software: los dominios rotan porque los proveedores de software usan CDNs con balanceo de carga que cambian las IPs semanalmente. No es indicativo de actividad maliciosa.
- **C)** El patrón indica un ataque de amplificación DNS en preparación: los dispositivos están siendo usados para realizar consultas DNS masivas que saturarán los servidores DNS del ISP. La rotación de dominios es para distribuir la carga del ataque.
- **D)** Los dominios con nombres generados algorítmicamente son una característica del protocolo IPv6 SLAAC, [Opcion cortada, pero no es la correcta].

Pregunta 11 (Opción Múltiple)

Escenario: Un atacante con control total sobre un servidor Windows elimina el contenido del registro de eventos de seguridad para ocultar su actividad. El sistema de correlación de eventos de la organización recopila logs en tiempo real con una latencia máxima de 30 segundos. El atacante ejecutó el borrado a las 14:32. Al día siguiente, el equipo forense revisa el sistema centralizado de logs. **Pregunta:** ¿Por qué el borrado de logs locales no eliminó la evidencia en el sistema centralizado, y qué ironía técnica presenta el propio acto de borrar los logs en Windows?

- **A)** El sistema centralizado conservó los logs porque tiene una copia de seguridad separada que se actualiza cada 24 horas, independientemente de la recopilación en tiempo real.
- **B)** El sistema centralizado conservó los logs porque opera en modo de solo escritura y los logs no pueden ser borrados remotamente desde el servidor comprometido, independientemente del nivel de privilegio del atacante.
- **C)** El borrado de logs locales no afecta al sistema centralizado porque ambos sistemas usan bases de datos diferentes y no están sincronizados. El sistema centralizado tiene su propia copia independiente de todos los eventos.
- **D)** Los eventos previos ya estaban almacenados en el sistema centralizado. Al intentar borrarlos localmente, Windows genera y transmite de inmediato un evento específico que registra dicha acción. Borrar los logs genera una nueva evidencia irrefutable y fechada que el atacante no puede eliminar del repositorio central, a menos que logre comprometer esa infraestructura de forma independiente.

Pregunta 12 (Opción Múltiple)

Escenario: Un atacante con privilegios de sistema en un servidor Windows necesita operar durante varias horas sin dejar registros en el visor de eventos. Evalúa dos enfoques: el primero usa la API de Windows para borrar los logs periódicamente; el

segundo parchea en memoria el proceso responsable del logging para que deje de procesar eventos sin usar ninguna API documentada de borrado. **Pregunta:** Desde la perspectiva de un analista forense que investiga el incidente días después, ¿cómo diferencia entre estos dos enfoques y qué evidencia residual deja cada uno?

- **A)** Un analista forense no puede diferenciar entre los dos enfoques porque ambos resultan en la misma ausencia de logs. La evidencia residual es idéntica: cero eventos en el registro.
- **B)** El primer enfoque es completamente no detectable porque los eventos de borrado solo se registran si el sistema de auditoría está habilitado. Si el atacante deshabilita la auditoría antes de borrar, no queda ningún rastro.
- **C)** El segundo enfoque es completamente no detectable porque al operar en memoria no deja artefactos en disco. Un análisis forense de disco no puede identificar modificaciones realizadas exclusivamente en memoria que no fueron persistidas.
- **D)** El primer enfoque genera eventos de borrado con timestamps precisos en logs centralizados, confirmando la acción deliberada. El segundo no genera estos eventos, pero deja una anomalía detectable: el servicio de logging aparece activo pero sin registros durante el incidente. Ambos enfoques son detectables; solo difieren en el tipo de evidencia que dejan.

Pregunta 14 (Opción Múltiple)

Escenario: Un administrador de red usa una herramienta de análisis de paquetes en modo promiscuo para diagnosticar un problema de rendimiento. Después de 2 horas de captura, encuentra que puede ver todo el tráfico de su propio equipo y los broadcasts de la red, pero no el tráfico entre otros pares de dispositivos en el mismo switch. El administrador concluye que la herramienta de análisis tiene un defecto. **Pregunta:** ¿Por qué la conclusión del administrador es incorrecta, y cuáles son las condiciones técnicas que limitaron la visibilidad de la captura?

- **A)** La conclusión es correcta: una herramienta de análisis en modo promiscuo debería capturar todo el tráfico del segmento. La limitación indica un defecto en la implementación de la herramienta.
- **B)** La herramienta funciona correctamente, pero el modo promiscuo solo captura tráfico broadcast y multicast en redes con switch. El tráfico unicast entre pares específicos nunca es visible para otros dispositivos en redes switched, independientemente de la herramienta o su configuración.
- **C)** El administrador debe actualizar los drivers de la interfaz de red: los drivers desactualizados no implementan correctamente el modo promiscuo y filtran el tráfico de otros dispositivos antes de que llegue al software de análisis.
- **D)** Falso. El modo promiscuo procesa todo lo que llega a la interfaz, pero el switch solo envía los frames unicast al puerto del destinatario real. El tráfico ajeno nunca llega físicamente al administrador. El modo promiscuo es

necesario pero no suficiente: depende de que el tráfico sea redirigido físicamente a ese puerto.

Pregunta 15 (Opción Múltiple)

Escenario: Durante una investigación forense de un servidor crítico comprometido, el analista confirma mediante registros de red externos que el servidor estuvo activo y tuvo sesiones de usuarios durante un período de 8 horas. Sin embargo, el visor de eventos local de Windows no contiene ningún registro de esas 8 horas. El servicio de visor de eventos aparece como 'en ejecución' en el administrador de servicios. **Pregunta:** ¿Qué indica la combinación de estas tres observaciones simultáneas (servicio activo, actividad de red confirmada, ausencia total de logs locales), y qué fuentes alternativas de evidencia debería priorizar el analista?

- **A)** Las tres observaciones son consistentes con un problema de hardware: un disco con sectores defectuosos puede perder registros de forma selectiva mientras el servicio permanece activo. El analista debe realizar un diagnóstico de disco antes de concluir manipulación.
- **B)** La ausencia de logs durante 8 horas indica que el servidor fue reiniciado y los logs fueron eliminados durante el arranque. El analista debe verificar el registro de eventos del sistema en busca de eventos de inicio del sistema que delimiten el período sin logs.
- **C)** El patrón indica que alguien con acceso de administrador simplemente puso el servicio en modo de depuración, que suspende el registro normal. Es una acción administrativa común y no necesariamente maliciosa.
- **D)** El patrón (servicio activo sin registros) indica una interrupción del pipeline de logging en memoria: el proceso sigue en ejecución pero su capacidad de registrar está neutralizada. A diferencia del borrado (que deja auditoría) o del servicio detenido (que es visible), este ataque requiere priorizar fuentes alternativas: logs de red (firewalls, IDS), registros de autenticación centralizada, logs de aplicaciones con canales propios y artefactos forenses de disco.

Pregunta 16 (Opción Múltiple)

Escenario: El IDS de una empresa genera 847 alertas en 15 minutos con el patrón: un origen IP interno enviando paquetes SYN a cada puerto de cada host de la red, en un barrido sistemático. El propietario de la IP origen afirma que no ejecutó ninguna herramienta de escaneo. El equipo forense confirma que el equipo del usuario no ejecutó ninguna herramienta visible, pero sí tiene un proceso de sistema con conexiones salientes inusuales. **Pregunta:** ¿Cómo reconcilia el equipo forense las dos afirmaciones aparentemente contradictorias (el usuario no ejecutó nada, el IDS detectó escaneo originado en su equipo), y qué implica esto para la investigación?

- **A)** Las afirmaciones son irreconciliables: si el IDS detectó el escaneo desde ese IP, el usuario debe haber ejecutado algo conscientemente. La negación del usuario no tiene credibilidad técnica.
- **B)** Ambas afirmaciones son ciertas si el equipo fue comprometido: es la fuente del tráfico, pero operado remotamente por un atacante. El proceso con conexiones inusuales delata al agente de control. La investigación debe centrarse en hallar este agente, su persistencia y verificar si el compromiso se ha extendido a otros equipos.
- **C)** El IDS generó falsos positivos: el tráfico SYN masivo fue generado por actualizaciones automáticas del sistema operativo que verifican la conectividad con múltiples hosts. El usuario es inocente y el IDS necesita ajuste de reglas.
- **D)** La explicación técnica es que el switch asignó incorrectamente el tráfico de otro dispositivo al puerto del usuario en la tabla MAC. El equipo del usuario no generó ese tráfico; el switch lo atribuyó incorrectamente.

Soluciones y Clave de Respuestas (Segundo Parcial Completo)

- **Pregunta 1:** D
- **Pregunta 2:** D
- **Pregunta 3:** B *(Recuerda la técnica de evasión de sandbox)*
- **Pregunta 4:** D
- **Pregunta 5:** B
- **Pregunta 6:** D
- **Pregunta 7:** D
- **Pregunta 8:** C
- **Pregunta 9:** D
- **Pregunta 10:** A
- **Pregunta 11:** D
- **Pregunta 12:** D
- **Pregunta 14:** D
- **Pregunta 15:** D
- **Pregunta 16:** B